



ARKA HEALTH, INC.

INFORMATION SECURITY POLICY

Master security policy implementing 45 C.F.R. Part 164, Subpart C and the SOC 2 Security category

ARKA-SEC-001 · Version 1.0 · Confidential — Internal

Document No.	ARKA-SEC-001
Version	1.0
Effective Date	June 10, 2026
Last Reviewed	June 10, 2026
Document Owner	Arri Kanna, Founder & Chief Executive Officer — Privacy & Security Officer
Approved By	Arri Kanna, Founder & Chief Executive Officer
Classification	Confidential — Internal
Review Cycle	Annual, and upon any material change in operations, systems, or law

This document contains confidential and proprietary information of ARKA Health, Inc. (“ARKA”). It is furnished for informational and compliance purposes, may not be reproduced or disclosed to any third party without the prior written consent of ARKA, and must be returned or destroyed upon request. Nothing in this document constitutes legal advice.

1. PURPOSE

This Information Security Policy (this “**Policy**”) is the master technical and organizational security policy of ARKA Health, Inc. (“**ARKA**”). It implements the HIPAA Security Rule, 45 C.F.R. Part 164, Subpart C, with respect to electronic Protected Health Information (“**ePHI**”), and the AICPA Trust Services Criteria (Security category) with respect to all systems within the description of the ARKA service organization. Where this Policy states a control objective implemented in greater detail by a subordinate policy in the ARKA-SEC series, the subordinate policy governs the implementation.

2. SECURITY PRINCIPLES

1. **Least privilege and need-to-know.** No Workforce Member or system component is granted access beyond that required for its documented function.
2. **Defense in depth.** Controls are layered — identity, network, application, and data — such that the failure of any single control does not result in the compromise of ePHI.
3. **Secure by default.** New systems, integrations, and configurations must deny access by default, encrypt by default, and log by default before entering production.
4. **No production PHI outside production.** ePHI shall not exist in development, test, staging, demonstration, or analytics environments; such environments use synthetic or de-identified data exclusively (ARKA-DEMO-001; ARKA-PRIV-002).
5. **Evidence or it did not happen.** Every recurring control activity required by this Policy series generates a dated artifact retained for six (6) years (45 C.F.R. § 164.316(b)).

3. SCOPE AND SYSTEM DESCRIPTION

This Policy applies to all information systems owned or operated by or on behalf of ARKA, including: the ARKA Platform application tier (Next.js services deployed on managed cloud infrastructure); managed database and authentication services (PostgreSQL via Supabase); cloud infrastructure accounts (Amazon Web Services and Vercel); source-code management and CI/CD (GitHub); corporate SaaS (productivity, communications); and Workforce Member endpoints. The Security Officer shall maintain, and review at least every twelve (12) months and upon material change, a **technology asset inventory** and a **network map** tracing the movement of ePHI through all such systems, consistent with proposed 45 C.F.R. § 164.308(a)(1) (90 Fed. Reg. 898).

4. CONTROL FRAMEWORK MAPPING

Domain	Implementing policy	Primary citations
Risk analysis & management	ARKA-SEC-002	§ 164.308(a)(1); TSC CC3, CC9
Workforce security; access	ARKA-SEC-003	§ 164.308(a)(3)–(4); § 164.312(a), (d); TSC CC6
Encryption & key management	ARKA-SEC-004	§ 164.312(a)(2)(iv), (e); TSC CC6.7
Logging & monitoring	ARKA-SEC-005	§ 164.312(b); TSC CC7.2–7.3
Incident response & breach	ARKA-SEC-006	§ 164.308(a)(6); §§ 164.400–414;

Domain	Implementing policy	Primary citations
		TSC CC7.4–7.5
Contingency & resilience	ARKA-SEC-007	§ 164.308(a)(7); § 164.310(d); TSC A1
Training & sanctions	ARKA-SEC-008	§ 164.308(a)(1)(ii)(C), (a)(5); TSC CC1.4–1.5
Vendor management	ARKA-SEC-009	§ 164.308(b); § 164.314(a); TSC CC9.2
SDLC & change management	ARKA-SEC-010	§ 164.312(c); TSC CC8.1
Data lifecycle & disposal	ARKA-SEC-011	§ 164.310(d)(2); TSC C1
Acceptable use & endpoints	ARKA-SEC-012	§ 164.310(b)–(c); TSC CC6.8

5. BASELINE TECHNICAL STANDARDS

The following minimums apply across all in-scope systems and may be strengthened, but not weakened, by subordinate policies: (a) multi-factor authentication on every account capable of reaching production systems, source code, or ePHI; (b) TLS 1.2 or higher for all data in transit, with TLS 1.3 preferred and HTTP Strict Transport Security enforced on all public endpoints; (c) AES-256 (or equivalent) encryption at rest for all data stores and backups; (d) centralized, immutable audit logging with retention per ARKA-SEC-005; (e) vulnerability scanning of production infrastructure and dependencies no less than every six (6) months (in practice, continuously via automated dependency and static-analysis tooling) and penetration testing by a qualified independent firm no less than every twelve (12) months; (f) network segmentation separating production from non-production and corporate environments; and (g) hardening of cloud accounts to CIS Benchmark guidance, with infrastructure configuration managed as code wherever supported.

6. ORGANIZATION AND ENFORCEMENT

The Security Officer designated under ARKA-GOV-001 is accountable for this Policy and reports to the Chief Executive Officer and the Security & Compliance Committee. Violations are sanctioned under ARKA-SEC-008. Exceptions require the written approval of the Security Officer, a compensating-control analysis, and an expiration date not exceeding ninety (90) days, recorded in the exception register.

DOCUMENT CONTROL & REVISION HISTORY

Version	Date	Author / Reviewer	Description of Change
0.9	May 22, 2026	A. Kanna (drafting); external review pending	Initial draft circulated for internal review and counsel comment.
1.0	June 10, 2026	A. Kanna, Privacy & Security Officer	Adopted as effective policy of ARKA Health, Inc. by written approval of the undersigned officer.

ADOPTION AND APPROVAL

The undersigned, being the duly designated Privacy Officer and Security Officer of ARKA Health, Inc., hereby adopts this document as an official policy of the Company, effective as of the Effective Date set forth on the cover page hereof. This document shall be reviewed no less frequently than annually and upon any material change to the Company's operations, information systems, or applicable law, and may be amended only in accordance with ARKA-GOV-001 (Information Security & Compliance Program Charter).

ARKA HEALTH, INC.

By: _____

Name: Arri Kanna

Title: Founder & Chief Executive Officer; Privacy & Security Officer

Date: June 10, 2026